title: "Cybersecurity Data Breach Policy" effectiveDate: "" reviewDate: "" version: "1.0"

Cybersecurity / Data Breach Policy

Policy Title: Cybersecurity / Data Breach Policy

Effective Date: [Insert Date]

Review Date: [Insert Date – usually annually]

Version: 1.0

Applies to: All staff, contractors, volunteers, and external partners at [INSERT CARE HOME NAME]

1. Policy Statement

At [INSERT CARE HOME NAME], we are committed to ensuring the security of all digital systems and protecting personal and sensitive data belonging to residents, staff, and the organisation. We recognise that cybersecurity threats and data breaches present serious risks to privacy, safety, and regulatory compliance.

We aim to:

- Safeguard confidential and sensitive information against unauthorised access, loss, or misuse
- Provide clear procedures for responding to actual or suspected data breaches
- Comply with the UK GDPR, Data Protection Act 2018, and Care Quality Commission (CQC) regulations
- Promote a culture of security awareness among all staff

2. Purpose

The purpose of this policy is to:

- Establish standards for maintaining cybersecurity within the care home
- Provide clear guidance for reporting and managing data breaches
- Reduce the risk of cyberattacks and unauthorised access to systems
- Ensure compliance with data protection legislation

3. Scope

This policy applies to:

- All staff members, contractors, and third parties handling electronic information

- All digital systems including computers, tablets, mobile devices, care planning systems, and cloud storage
- All types of data, including resident information, staff records, financial data, and operational documents

4. Roles and Responsibilities

Registered Manager (Data Controller):

- Ensures compliance with data protection and cybersecurity regulations
- Investigates and reports data breaches to the ICO (Information Commissioner's Office) within 72 hours, where required
- Provides guidance and training to staff

Data Protection Officer (if appointed):

- Oversees data protection practices and audits
- Acts as the contact point for regulatory authorities

All Staff:

- Use IT systems responsibly and in line with this policy
- Protect login credentials and never share passwords
- Report suspected cybersecurity incidents or breaches immediately

IT Support / Contractors:

- Maintain secure systems with appropriate firewalls, encryption, and anti-virus protection
- Carry out regular system updates and patches
- Support the investigation of data breaches

5. Cybersecurity Standards

5.1 Access Control

- All systems must be password-protected with strong, unique passwords
- Access levels granted only as necessary for staff roles
- Staff accounts must be deactivated promptly when employment ends

5.2 Device Security

- All care home devices must be password-protected and encrypted where possible
- Personal devices must not be used for work purposes unless authorised and secure
- Lost or stolen devices must be reported immediately

5.3 Email and Internet Use

- Staff must not open suspicious emails, links, or attachments
- Work emails must not be used for personal purposes
- Downloads from untrusted sources are prohibited

5.4 Data Storage and Transfer

- Resident and staff data must be stored securely on approved systems
- Use of USB drives or portable storage is restricted and must be encrypted if authorised
- Data must never be shared via personal email or unsecured platforms

6. Data Breach Management

6.1 Identifying a Data Breach

A data breach may include:

- Loss or theft of devices containing personal information
- Unauthorised access to electronic systems
- Accidental sharing of confidential information
- Cyberattacks such as malware, ransomware, or phishing

6.2 Reporting a Data Breach

- All staff must report suspected or confirmed data breaches immediately to the Registered Manager or DPO
- A Data Breach Incident Report must be completed

6.3 Responding to a Data Breach

- The Registered Manager will investigate the breach and contain it where possible
- Risk assessment will be carried out to determine impact on individuals and the organisation
- ICO and affected individuals will be notified within 72 hours where required by law

6.4 Learning and Prevention

- Root cause analysis will be carried out
- Policies, systems, and training will be updated to prevent recurrence

7. Training and Awareness

- All staff will receive induction and refresher training on cybersecurity and data protection
- Staff will be reminded of common cyber threats and safe practices (e.g., phishing awareness)
- Training records will be maintained

8. Monitoring and Audit

- Regular audits of IT systems and data security practices will be conducted
- Access logs and activity records will be reviewed
- Findings will feed into the Quality Assurance & Audit process

9. References

- Data Protection Act 2018 / UK GDPR
- ICO Guidance on Data Breach Management
- Health and Social Care Act 2008 (Regulated Activities) Regulations 2014
- CQC Fundamental Standards – Regulation 17 (Good Governance)

10. Related Policies

- Confidentiality / GDPR Policy
- Information Sharing Policy
- Record Keeping Policy
- Staff Training & Development Policy
- Business Continuity & Emergency Planning Policy

Generated by Docuflow